

ISO SECURE

Plataforma de Cumplimiento ISO 27001

Etapa 1: Análisis e Ingeniería de Requerimientos

Actividad Formativa 1 - 5 %

Agustín Peralta — Universidad de San Buenaventura

Entrega: 25 de Mayo de 2026

Resumen

Este documento consolida los requerimientos de seguridad, funcionales y no funcionales del proyecto ISO SECURE, un sistema web para la gestión de seguridad de la información (SGSI) conforme a ISO/IEC 27001:2022. Incluye historias de usuario, casos de uso, casos de abuso y matriz de trazabilidad.

Índice

1. Introducción	3
2. Requerimientos de Seguridad	3
2.1. Confidencialidad (CIA — C)	3
2.2. Integridad (CIA — I)	3
2.3. Disponibilidad (CIA — A)	4
2.4. Adicionales (OWASP)	4
3. Requerimientos Funcionales	4
3.1. RF-1: Autenticación y Gestión de Usuarios	4
3.2. RF-2: Gestión de Controles ISO 27001	5
3.3. RF-3: Gestión de Incidentes de Seguridad	5
3.4. RF-4: Evaluación de Riesgos	6
3.5. RF-5: Capacitaciones	6
3.6. RF-6: Auditoría Interna	6
3.7. RF-7: Reportes y Exportación	6
4. Requerimientos No Funcionales	7
5. Historias de Usuario	7
5.1. HU-1: Auditor — Consultar cumplimiento por empresa	7
5.2. HU-2: Supervisor — Cambiar estado de control	8
5.3. HU-3: Analista — Registrar incidente de seguridad	8

5.4.	HU-4: Admin — Gestionar usuarios y roles	8
5.5.	HU-5: Usuario — Realizar capacitación	9
5.6.	HU-6: Auditor — Evaluar riesgo	9
5.7.	HU-7: Admin — Generar reporte ejecutivo	9
6.	Casos de Uso	10
6.1.	CU-1: Implementar un control ISO	10
6.2.	CU-2: Gestionar incidente de seguridad	10
6.3.	CU-3: Realizar auditoría interna	11
7.	Casos de Abuso	11
7.1.	CA-1: Atacante intenta SQL injection	11
7.2.	CA-2: Usuario intenta acceder a datos de otra empresa	11
7.3.	CA-3: Admin deshabilitado intenta reasignarse rol	12
7.4.	CA-4: Auditor intenta modificar incidente ajeno	12
7.5.	CA-5: Token JWT interceptado (MITM)	12
7.6.	CA-6: XSS en campo de comentarios	13
8.	Matriz de Trazabilidad	13
9.	Métricas de Cobertura	14
10.	Conclusiones	14

1. Introducción

ISO SECURE es una plataforma web integral para:

- Gestionar y auditar 93 controles ISO 27001 Anexo A
- Registrar y analizar incidentes de seguridad
- Evaluar riesgos por dominio ISO (matriz Probabilidad x Impacto)
- Capacitar a personal en seguridad de la información
- Generar reportes ejecutivos y KPIs para la alta dirección

Stack: FastAPI (Python 3.13) + React 19 + PostgreSQL 15 (Supabase) + Supabase Auth (JWT)

Alcance: Sistema multi-tenant con 4 roles (admin, auditor, supervisor, analista) y 9 módulos operacionales.

2. Requerimientos de Seguridad

Los requerimientos de seguridad están alineados con ISO/IEC 27001:2022 y OWASP Top 10 (2024).

2.1. Confidencialidad (CIA - C)

- [SEC-C] **SEC-C-1:** Autenticación obligatoria: todo usuario debe autenticarse vía JWT (Supabase OAuth 2.0) antes de acceder a recursos.
- [SEC-C] **SEC-C-2:** Control de acceso granular: cada acción (read, write, delete) validada según rol del usuario y pertenencia a empresa (multi-tenant).
- [SEC-C] **SEC-C-3:** Cifrado en tránsito: todas las comunicaciones backend-frontend vía HTTPS (TLS 1.3+).
- [SEC-C] **SEC-C-4:** Cifrado en reposo: credenciales, tokens sensibles cifrados en BD (Supabase built-in).
- [SEC-C] **SEC-C-5:** CORS restringido: solo dominios autorizados pueden hacer requests (whitelist en FastAPI).

2.2. Integridad (CIA - I)

- [SEC-I] **SEC-I-1:** Validación de entrada: todos los payloads validados con Pydantic v2 (type hints + constraints).
- [SEC-I] **SEC-I-2:** Prevención SQL injection: SQLAlchemy ORM con prepared statements (no raw SQL).
- [SEC-I] **SEC-I-3:** CSRF protection: tokens CSRF en formularios críticos (si aplica SSR; React con Axios maneja).

- [SEC-I] **SEC-I-4:** Integridad de datos: checksums o versionado para cambios en controles y riesgos.
- [SEC-I] **SEC-I-5:** Auditoría de cambios: toda modificación (create, update, delete) registrada en tabla de auditoría con timestamp, usuario, acción y deltas.

2.3. Disponibilidad (CIA - A)

- [SEC-A] **SEC-A-1:** Rate limiting: máximo 100 requests/minuto por IP; 50/min por usuario autenticado.
- [SEC-A] **SEC-A-2:** Timeout de sesión: JWT expira en 1 hora; refresh token en 7 días.
- [SEC-A] **SEC-A-3:** Resiliencia: base de datos replicada (Supabase built-in); backend sin estado (stateless).
- [SEC-A] **SEC-A-4:** Logging y monitoreo: registro centralizado de eventos de seguridad (intentos de acceso fallidos, cambios de permisos).

2.4. Adicionales (OWASP)

- [SEC-X] **SEC-X-1:** Content Security Policy (CSP): header restrictivo ('default-src 'self'', etc.) contra XSS.
- [SEC-X] **SEC-X-2:** X-Frame-Options: 'DENY' para prevenir clickjacking.
- [SEC-X] **SEC-X-3:** X-Content-Type-Options: 'nosniff' para prevenir MIME sniffing.
- [SEC-X] **SEC-X-4:** HSTS: Strict-Transport-Security con max-age=31536000.
- [SEC-X] **SEC-X-5:** Permissions-Policy: desactivar cámara, micrófono, geolocalización.

3. Requerimientos Funcionales

3.1. RF-1: Autenticación y Gestión de Usuarios

ID	RF-1.1
Nombre	Registro de usuario
Descripción	Un nuevo usuario puede registrarse con email y contraseña; se valida unicidad de email y se envía token de confirmación.
Actores	Usuario anónimo
Precondición	Email no registrado previamente
Postcondición	Perfil de usuario creado; email de confirmación enviado
ID	RF-1.2
Nombre	Login
Descripción	Usuario autenticado recibe JWT token (válido 1 hora) y refresh token (válido 7 días).
Actores	Usuario registrado
Precondición	Email y contraseña correctos
Postcondición	Tokens almacenados en localStorage; usuario redirigido a dashboard

ID	RF-1.3
Nombre	Gestión de roles y permisos
Descripción	Admin puede asignar roles a usuarios (admin, auditor, supervisor, analista). Cada rol tiene permisos sobre 11 vistas.
Actores	Admin
Precondición	Usuario existente; admin autenticado
Postcondición	Rol asignado; permisos actualizados dinámicamente

3.2. RF-2: Gestión de Controles ISO 27001

ID	RF-2.1
Nombre	Consultar catálogo de controles
Descripción	Auditor/Supervisor visualiza 93 controles ISO Anexo A filtrados por empresa, dominio (A.5 a A.18) y estado (<i>no_iniciado, en_proceso, implementado, etc.</i>).
Actores	Auditor, Supervisor
Precondición	Usuario autenticado
Postcondición	Lista de controles mostrada con filtros y búsqueda
ID	RF-2.2
Nombre	Actualizar estado de control
Descripción	Supervisor puede cambiar el estado de un control (<i>no_iniciado</i> → <i>en_proceso</i> → <i>implementado</i> → <i>auditado</i>).
Actores	Supervisor
Precondición	Control existente; Supervisor autenticado
Postcondición	Estado actualizado; auditoría registrada
ID	RF-2.3
Nombre	Calcular indicador de cumplimiento
Descripción	Sistema calcula automáticamente el porcentaje de cumplimiento como $(\text{controles_implementados} / \text{total_controles}) \times 100$.
Actores	Sistema
Precondición	Al menos 1 control registrado
Postcondición	KPI mostrado en dashboard

3.3. RF-3: Gestión de Incidentes de Seguridad

ID	RF-3.1
Nombre	Registrar incidente
Descripción	Analista crea incidente con: descripción, severidad (1-5), empresa, fecha de detección, estado inicial (abierto).
Actores	Analista
Precondición	Incidente detectado
Postcondición	Incidente almacenado; notificación a auditor
ID	RF-3.2
Nombre	Calcular MTTR (Mean Time To Resolve)
Descripción	Para incidentes cerrados, $\text{MTTR} = \text{fecha_cierre} - \text{fecha_apertura}$ (en horas). Dashboard muestra promedio por empresa.
Actores	Sistema
Precondición	Incidente cerrado
Postcondición	KPI MTTR actualizado

3.4. RF-4: Evaluación de Riesgos

ID	RF-4.1
Nombre	Crear evaluación de riesgo
Descripción	Auditor registra riesgo con: descripción, probabilidad (1-5), impacto (1-5), dominio ISO, estado. Riesgo = P x I (1-25).
Actores	Auditor
Precondición	Riesgo identificado
Postcondición	Riesgo registrado; matriz de riesgo actualizada
ID	RF-4.2
Nombre	Visualizar matriz de riesgo
Descripción	Dashboard muestra matriz 5x5 (PxI) con color: verde (1-5), amarillo (6-12), rojo (13-25). Drill-down a riesgos por celda.
Actores	Admin, Auditor
Precondición	Al menos 1 riesgo registrado
Postcondición	Matriz visualizada

3.5. RF-5: Capacitaciones

ID	RF-5.1
Nombre	Acceder a cursos de seguridad
Descripción	Usuario puede ver catálogo de cursos (SGSI 101, ISO 27001 Basics, Phishing Awareness, etc.), reproducir video y marcar como completado.
Actores	Cualquier usuario autenticado
Precondición	Cursos cargados en BD
Postcondición	Progreso registrado

3.6. RF-6: Auditoría Interna

ID	RF-6.1
Nombre	Ejecutar checklist de auditoría
Descripción	Auditor marca items de checklist pre-configurado (ej: "¿Se implementó control A.5.1?"). Sistema calcula Actores
Actores	Auditor
Precondición	Checklist definido
Postcondición	Resultados almacenados; informe generado

3.7. RF-7: Reportes y Exportación

ID	RF-7.1
Nombre	Exportar reporte ejecutivo
Descripción	Admin/Auditor genera PDF con: KPIs, matriz de riesgos, tabla de controles, gráficos MTTR, progreso capacitación.
Actores	Admin, Auditor
Precondición	Datos disponibles
Postcondición	PDF descargado; webhook a n8n para procesamiento

4. Requerimientos No Funcionales

RNF-1	Performance — Latencia máxima 200ms (p95) para GET; 500ms (p95) para POST.
RNF-2	Escalabilidad — Capacidad para 1000 usuarios concurrentes por empresa; 100 empresas máximo (MVP).
RNF-3	Disponibilidad — Uptime 99.5 % (SLA Supabase). Recovery Time Objective (RTO) < 1 hora.
RNF-4	Usabilidad — Interfaz responsive (mobile, tablet, desktop); accesibilidad WCAG 2.1 AA mínimo.
RNF-5	Mantenibilidad — Código documentado (docstrings); commits atómicos; CI/CD con tests automáticos.
RNF-6	Portabilidad — Docker containerizado; deployment multi-cloud compatible.
RNF-7	Confiabilidad — MTBF > 720 horas; MTTR < 2 horas para incident crítico.
RNF-8 Chrome 120+, Firefox 121+, Safari 17+, Edge 120+.	Compatibilidad

5. Historias de Usuario

5.1. HU-1: Auditor - Consultar cumplimiento por empresa

Como auditor de seguridad

Quiero visualizar el porcentaje de cumplimiento de controles ISO 27001 para cada empresa en el sistema

Para identificar rápidamente cuál organización necesita más esfuerzo en implementación

Criterios de Aceptación:

1. Mostrar tabla con: Empresa | Total Controles | Implementados | % Cumplimiento | Tendencia
2. Filtro por rango de fechas
3. Exportar a CSV
4. Drill-down: clic en empresa abre detalle de controles por estado

5.2. HU-2: Supervisor - Cambiar estado de control

Como supervisor de implementación

Quiero actualizar el estado de un control ISO (no_iniciado -> en_proceso -> implementado -> auditado)

Para llevar un seguimiento de progreso y comunicar avances al team

Criterios de Aceptación:

1. Dropdown con transiciones válidas (no todos los estados son alcanzables de uno)
2. Comentario obligatorio al cambiar de estado
3. Auditoría: registrar quién, cuándo, de qué a qué
4. Notificación a auditor si hay cambio crítico

5.3. HU-3: Analista - Registrar incidente de seguridad

Como analista de incidentes

Quiero registrar un incidente detectado (malware, acceso no autorizado, leak, etc.)

Para mantener historial de eventos y calcular métricas (MTTR, tasa de resolución)

Criterios de Aceptación:

1. Formulario con: descripción, severidad (1-5), fecha detección, empresa afectada, dominio ISO relacionado (opcional)
2. Validación: severidad requerida; descripción mín 10 caracteres
3. Email de notificación al auditor
4. Link a reporte de incidente en 24h

5.4. HU-4: Admin - Gestionar usuarios y roles

Como administrador del sistema

Quiero crear, editar, eliminar usuarios y asignarles roles

Para controlar quién accede a qué datos en cada empresa

Criterios de Aceptación:

1. CRUD completo: crear (email validado), editar (nombre, rol, empresa), desactivar (no borrar)
2. Visualización de último login
3. Bulk actions: asignar rol a múltiples usuarios
4. Auditoría completa de cambios de rol

5.5. HU-5: Usuario - Realizar capacitación

Como empleado de la organización

Quiero acceder a cursos de seguridad (SGSI 101, Phishing Awareness, etc.)

Para cumplir con el requerimiento de capacitación obligatoria

Criterios de Aceptación:

1. Catálogo de cursos con video embebido (YouTube o similar)
2. Progreso visual (barra %)
3. Certificado descargable al completar
4. Recordatorio si no completa en 30 días

5.6. HU-6: Auditor - Evaluar riesgo

Como auditor de riesgos

Quiero registrar una evaluación de riesgo (descripción, probabilidad, impacto, dominio ISO)

Para alimentar la matriz de riesgos y generar hoja de ruta de mitigación

Criterios de Aceptación:

1. Formulario: descripción, P (1-5), I (1-5), dominio ISO, estado
2. Cálculo automático de riesgo (P x I)
3. Matriz 5x5 actualizada en tiempo real
4. Sugerencia de mitigaciones basadas en riesgo

5.7. HU-7: Admin — Generar reporte ejecutivo

Como director de seguridad

Quiero exportar un reporte PDF con KPIs, gráficos, matriz de riesgos para la junta directiva

Para documentar el estado del SGSI y justificar inversión en seguridad

Criterios de Aceptación:

1. PDF con: portada, indice, KPIs (cumplimiento %, MTTR, tasa incidentes), gráficos Chart.js, tabla de riesgos, tabla de controles críticos
2. Watermark “Confidencial”
3. Timestamp de generación
4. Opción de programar generación mensual

6. Casos de Uso

6.1. CU-1: Implementar un control ISO

Actores: Supervisor (principal), Auditor (secundario), Sistema

Precondición: Control existe; Supervisor autenticado

Flujo Principal:

1. Supervisor abre módulo “Controles”
2. Selecciona control con estado “no_iniciado”
3. Hace clic en “Cambiar Estado” -> “En Proceso”
4. Comenta: “Iniciado implementación de A.5.1 Control de Acceso”
5. Sistema registra cambio; notifica a Auditor
6. Supervisor cambia a “Implementado” cuando finaliza
7. Auditor revisa; cambia a “Auditado” si aprueba

Flujo Alternativo (A1): Supervisor añade evidencia (documento, screenshot)

1. En paso 3, hace upload de archivo (PDF, JPG máx 5MB)
2. Sistema valida y almacena; crea thumbnail para preview

Postcondición: Control en estado “Auditado”; auditoría registrada; KPI cumplimiento actualizado

6.2. CU-2: Gestionar incidente de seguridad

Actores: Analista (principal), Auditor (secundario), Sistema, Correo

Precondición: Incidente detectado; Analista autenticado

Flujo Principal:

1. Analista accede a “Incidentes” -> “Crear Nuevo”
2. Rellena: título, descripción, severidad (ej: 4), empresa afectada, fecha detección
3. Selecciona dominio ISO relacionado (A.12.3 Logging)
4. Envía; sistema crea ID único (ej: INC-2026-001)
5. Auditor recibe notificación por email
6. Analista/Auditor registran acciones de mitigación en pestaña “Actividades”
7. Cuando resuelven, cambian a “Cerrado”; sistema calcula MTTR automáticamente

Flujo Alternativo (A1): Incidente escala a crítico

1. Si severidad ≥ 4 , sistema envía SMS y llamada a on-call

Postcondición: Incidente registrado; MTTR calculado; KPI de incidentes actualizado

6.3. CU-3: Realizar auditoría interna

Actores: Auditor (principal), Sistema

Precondición: Checklist definido; Auditor autenticado

Flujo Principal:

1. Auditor abre “Auditoría” -> “Nueva Auditoría Interna”
2. Selecciona empresa y período (ej: Abril 2026)
3. Abre checklist pre-cargado (15 items)
4. Para cada item, marca: Cumple / No Cumple / Parcial / No Aplica
5. Agrega comentarios y evidencia (links)
6. Calcula automáticamente % cumplimiento
7. Genera borrador de reporte
8. Envía para aprobación del Auditor Jefe
9. Una vez aprobado, marca como “Finalizado”

Postcondición: Reporte de auditoría registrado; KPI de auditoría actualizado; notificación a Auditor Jefe

7. Casos de Abuso

7.1. CA-1: Atacante intenta SQL injection

Actor Malicioso: Atacante externo

Contexto: API REST en /api/controls

Escenario de Ataque:

1. Atacante intenta: GET /api/controls?filter=id=1 OR 1=1
2. Sistema debe rechazar con error 400 (Bad Request)

Mitigación:

OK SQLAlchemy ORM con prepared statements (no raw SQL)

OK Validación Pydantic en todos los inputs

7.2. CA-2: Usuario intenta acceder a datos de otra empresa

Actor Malicioso: Usuario autenticado (insider)

Contexto: Multi-tenancy

Escenario de Ataque:

1. Usuario de Empresa A intenta: GET /api/incidents?empresa_id=999 (Empresa B)

2. Sistema debe rechazar con 403 (Forbidden)

Mitigación:

OK Middleware de autorización: valida empresa_id del token vs. parámetro

OK Row-level security en BD (Supabase RLS)

7.3. CA-3: Admin deshabilitado intenta reasignarse rol

Actor Malicioso: Admin cuya cuenta fue desactivada

Contexto: JWT válido pero usuario desactivado

Escenario de Ataque:

1. Admin desactivado recibe JWT antes de ser desactivado
2. Intenta: POST /api/users/me/role con rol=admin
3. Sistema debe rechazar verificando campo activo=False

Mitigación:

OK En cada request, verificar estado de usuario (en caché o BD)

OK Invalidar JWT si usuario está inactivo

7.4. CA-4: Auditor intenta modificar incidente ajeno

Actor Malicioso: Auditor de Empresa A

Contexto: RBAC insuficiente

Escenario de Ataque:

1. Auditor A intenta: PATCH /api/incidents/123 (pertenece a Empresa B)
2. Sistema debe rechazar con 403

Mitigación:

OK Verificar owner (empresa_id) en middleware

OK Auditor solo puede leer/modificar datos de su propia empresa

7.5. CA-5: Token JWT interceptado (MITM)

Actor Malicioso: Atacante de red (MITM)

Contexto: Comunicación cliente-servidor

Escenario de Ataque:

1. Atacante intercepta JWT en tránsito
2. Intenta reutilizarlo desde otra IP
3. Sistema debe detectar anomalía o expiración

Mitigación:

- OK HTTPS obligatorio (TLS 1.3)
- OK JWT con expiry corto (1 hora)
- OK Refresh token separado (7 días, HttpOnly)
- OK IP binding opcional (Supabase setting)

7.6. CA-6: XSS en campo de comentarios

Actor Malicioso: Supervisor

Contexto: Formulario de “Comentario en Control”

Escenario de Ataque:

1. Supervisor ingresa: `<img src=x onerror=.alert('XSS')">`
2. Si no se sanitiza, ejecuta JavaScript en navegador de Auditor

Mitigación:

- OK Sanitización en backend (Bleach o similar) antes de guardar
- OK CSP header: `script-src 'self'` (bloquea inline scripts)
- OK React escapa valores por defecto en JSX

8. Matriz de Trazabilidad

La siguiente tabla relaciona Historias de Usuario (HU) con Requerimientos Funcionales (RF) y Controles ISO.

HU	RF Relacionados	Controles ISO	Endpoints	
HU-1	RF-2.1, RF-2.3	A.5.15, A.9.2	GET /api/controls, GET /dashboard/kpis	
HU-2	RF-2.2, RF-6.1	A.5.15, A.9.4	PATCH /api/controls/{id}, POST /api/auditoria	
HU-3	RF-3.1, RF-3.2	A.12.4, A.16.1	POST /api/incidents, GET /api/incidents	
HU-4	RF-1.3	A.5.1, A.6.2	POST/PATCH/DELETE /api/users, GET /api/users	
HU-5	RF-5.1	A.7.2, A.7.3	GET /api/capacitaciones, PATCH /api/curso-progreso	
HU-6	RF-4.1, RF-4.2	A.12.6, A.14.1	POST /api/risk, GET /api/risk/matriz	
HU-7	RF-7.1	A.5.1, A.16.1	POST /api/reportes/export-pdf	

9. Métricas de Cobertura

- **Historias de Usuario:** 7 HU definidas
- **Casos de Uso:** 3 CU principales
- **Casos de Abuso:** 6 CA identificados
- **Requerimientos Funcionales:** 14 RF (7 módulos)
- **Requerimientos No Funcionales:** 8 RNF
- **Requerimientos de Seguridad:** 16 SEC (CIA + OWASP)
- **Endpoints API:** 39 endpoints REST
- **Tablas BD:** 9 tablas (multi-tenant)
- **Controles ISO:** 93 controles (Anexo A)

10. Conclusiones

Los requerimientos de ISO SECURE cubren un espectro completo desde seguridad (17 controles) hasta funcionalidad (14 requerimientos), con énfasis en:

1. **Seguridad by Design:** CIA + OWASP integrados
2. **Multi-tenancy:** Aislamiento de datos por empresa
3. **RBAC granular:** 4 roles con 11 vistas diferenciadas
4. **Trazabilidad completa:** HU <-> RF <-> Controles ISO <-> Endpoints
5. **Resiliencia:** Auditoría de cambios, MTTR/MTBF, RLS en BD

Este documento servirá como referencia para las Etapas 2-5 (Arquitectura, Codificación, Pruebas, Entrega).

*Documento generado: 21 de mayo de 2026
Etapa 1 - Análisis e Ingeniería de Requerimientos
Universidad de San Buenaventura - Ingeniería de Sistemas*